

K3: Firewalls, Policy Enforcement & IPsec VPNs

Christopher Scherb <christopher.scherb@fhnw.ch>

FHNW Hochschule für Technik

16. Oktober 2025

Agenda

- ▶ Firewall-Grundlagen und Entscheidungslogik
- ▶ Access Lists als Basis der Policy Enforcement
- ▶ Zonenbasierte Firewalls und Betriebsprozesse
- ▶ Deep Packet Inspection und NGFW-Services
- ▶ IPsec VPN Konzepte, Aushandlung und Betrieb
- ▶ Appendix: Konsolidierte CLI-Referenzen

Lernziele

- ▶ Architektur und Grenzen klassischer, stateful und NGFW-Lösungen erklären.
- ▶ ACL- und Zonen-basierte Policies methodisch entwerfen und bewerten.
- ▶ DPI- und Threat-Intelligence-Funktionen kritisch einordnen (Sichtbarkeit vs. Aufwand).
- ▶ IPsec-Bausteine, Aushandlungsphasen und Betriebskennzahlen sicher anwenden.
- ▶ Wichtige CLI-Kommandos zielgerichtet nutzen (siehe Appendix).

Firewall Fundamentals

Evolution des Firewallings

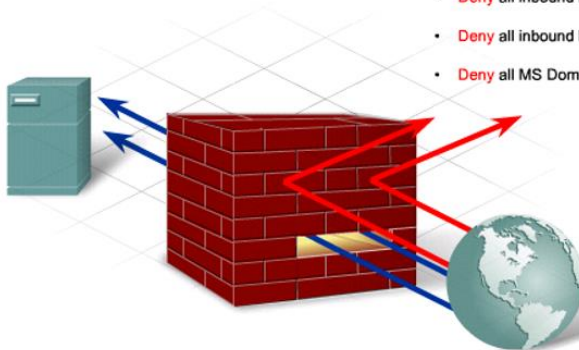
- ▶ **Paketfilter (ACL):** Fokus auf L3/L4-Header, schnelle, aber leicht zu umgehende Kontrolle.
- ▶ **Stateful Inspection:** Verbindungs-Tabelle mit 5-Tupel, Sequenznummern, Timeouts; Standard seit Ende der 1990er.
- ▶ **Application Gateways/Proxy:** Verständnis von Protokollzuständen (HTTP, FTP, SIP) und Request-Validierung.
- ▶ **Next-Generation Firewall:** Kombination aus Routing, VPN, DPI, Benutzer-Identität, Threat Feeds.
- ▶ Wachstum getrieben durch verschlüsselten Verkehr, Zero Trust und Cloud-Workloads.

Aufgaben und Grenzen einer Firewall

- ▶ Schutz eines Zielnetzes durch Filtern von Verbindungsaufbauten am Übergang zwischen Netzen.
- ▶ Zentrale Durchsetzung von Unternehmensrichtlinien und gesetzlicher Vorgaben (Audit-Trail, Nachvollziehbarkeit).
- ▶ Mögliche Nachteile: Fehlkonfigurationen, Single Point of Failure, Performanceeinfluss, 'Tunneling' verbotener Inhalte.
- ▶ NAT als Hürde: zustandsgebunden, aber kein Ersatz für Policy Enforcement; gezielte Löcher von innen sind möglich.

Sicherung von Netzen – Referenzszenarien

- **Allow** web traffic from any external address to the web server
- **Allow** traffic to FTP server
- **Allow** traffic to SMTP server
- **Allow** traffic to internal IMAP server
- **Deny** all inbound traffic with network addresses matching internal-registered IP addresses
- **Deny** all inbound traffic to server from external addresses
- **Deny** all inbound ICMP echo request traffic
- **Deny** all inbound MS Active Directory
- **Deny** all inbound MS SQL server ports
- **Deny** all MS Domain Local Broadcasts



Decision Stack einer Firewall

- ▶ Pfadauswahl: Routing-Entscheidung bestimmt, ob das Paket die Firewall erreicht.
- ▶ Adresse/Port-Normalisierung: NAT und ALG passen Header an, bevor Regeln greifen.
- ▶ Policy Evaluation: Sequenzielle Verarbeitung (Top-Down, first match). Implizites deny am Ende.
- ▶ Session Management: Erfolgreiche Flows landen in der State Table, Rückkanal wird dynamisch freigegeben.
- ▶ Logging/Telemetry: Jede Entscheidung muss im Betriebsalltag nachvollziehbar, korreliert und auditierbar sein.

State Table Grundlagen

- ▶ Speichert Verbindungszustände (TCP-Flags, Sequenzbereiche, Timeouts, Zonen-IDs).
- ▶ Rückkanäle werden dynamisch geöffnet; nicht konforme Pakete werden gedroppt.
- ▶ Protokollvalidierung verhindert 'session hijacking' (Flags, Fenster, Checksummen).

Session-Handling: DoS & Dynamische Protokolle

- ▶ Heuristiken: SYN-Proxy, embryonische Verbindungen, Anomalie-Scores.
- ▶ Dynamische Protokolle (FTP, SIP, H.323) benötigen ALGs zur Portfreigabe.
- ▶ Ressourcen-Management: Max. Sessions, Zonen-Limits, Aging gegen Table-Exhaustion.

Sicherheitswirkung und Grenzen

- ▶ Firewalls erzwingen Policy an Netzwerkgrenzen; Einsatz als 'Single Point of Control'.
- ▶ Wirksam gegen unverlangte eingehende Verbindungen, Teile von Command-and-Control und bekannten Exploits.
- ▶ Grenzen bei verschlüsseltem Verkehr ohne TLS-Inspection, Insider-Bedrohungen und seitlichen Bewegungen innerhalb einer Zone.
- ▶ Fehlkonfigurationen (zu breite Regeln, Schattenregeln, fehlende Rezertifizierung) stellen das größere Risiko dar.
- ▶ Ergänzende Kontrollen (NAC, EDR, Microsegmentation) notwendig für Defense in Depth.

Access Lists

ACL-Typen und Einsatzfelder

- ▶ **Standard ACL:** Filtert nur auf Source-IP, geeignet für einfache Outbound-Filter oder Route-Maps.
- ▶ **Extended ACL:** Prüft Source, Destination, Protokoll, Ports; Grundlage für Stateful-Firewall-Policies.
- ▶ **Named ACL:** Erleichtert Wartung, erlaubt das Einfügen neuer Regeln ohne komplette Neuerstellung.
- ▶ Nutzen als Vorfilter (z. B. Management Plane Protection), QoS-Classifikator oder 'Interesting Traffic' für VPNs.

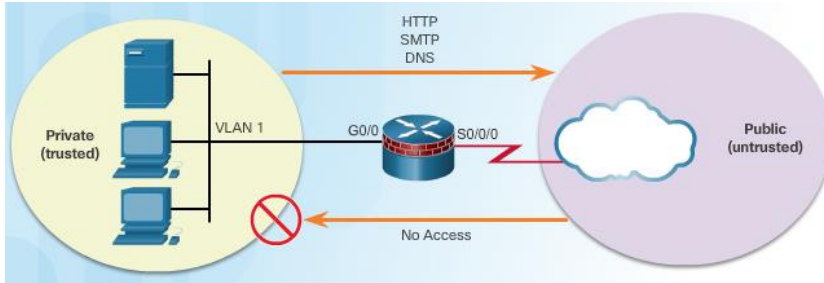
Evaluationslogik und Implikationen

- ▶ ACLs werden top-down ausgewertet; erster Treffer entscheidet, danach erfolgt keine weitere Prüfung.
- ▶ Implizites 'deny any' am Ende, daher müssen legitime Ausnahmen vollständig beschrieben werden.
- ▶ Reihenfolge kritischer Regeln definieren: spezifische Erlaubnisse vor allgemeinen Verboten.
- ▶ Logging sollte selektiv auf deny-Regeln aktiviert werden, um Rauschen zu vermeiden und Anomalien sichtbar zu machen.

ACLs in Netzentwürfen

- ▶ Platzierung an Randzonen (Edge/Provider, Übergang zu Partnern) reduziert Angriffsfläche.
- ▶ Nutzung als Vorfilter vor stateful/Layer-7-Inspektion, um Last zu senken (z. B. Drop 'Bogons', verbotene UDP-).
- ▶ Beispiele für Policy-Tabellen: Quelle-Zone, Ziel-Zone, Service, Begründung, Kritikalität, Owner, Ablaufdatum.
- ▶ Review-Zyklus: halbjährliche Re-Zertifizierung und automatisierte Reports zu ungenutzten Einträgen.

ACL-Policy – Visualisierung



Herausforderungen im Betrieb

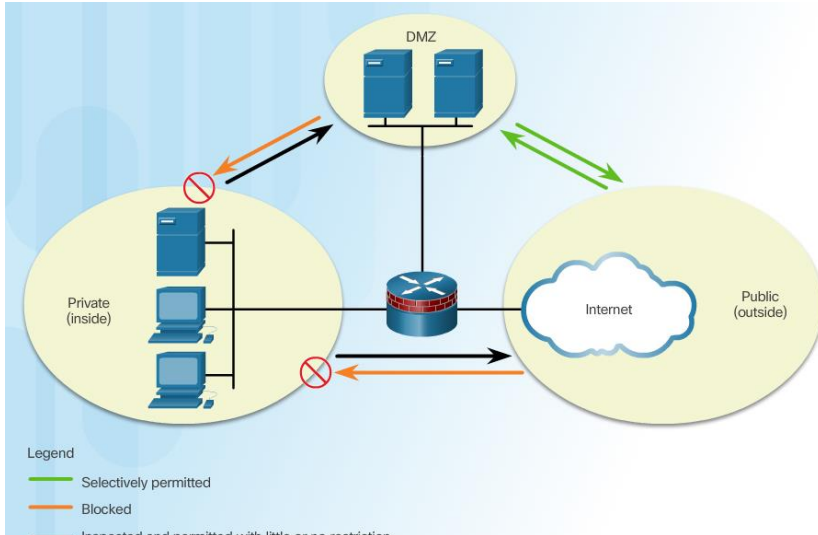
- ▶ Kein Zustandsverständnis: Rückkanal muss aktiv erlaubt werden (z. B. TCP-ACK oder dynamische Ports).
- ▶ Applikationen mit dynamischen Ports (VoIP, RPC) erzeugen große Regelwerke oder bleiben ungeschützt.
- ▶ Fehlende Objektabstraktion führt zu IP-basierten Regeln, die bei Umnummerierungen schnell veralten.
- ▶ Konsistente Dokumentation (Ticket-ID, Owner, Begründung) fehlt oft und erschwert Audits.

Best Practices zur ACL-Pflege

- ▶ Benutzen von Objekt-, Service- und Zeit-Gruppen zur Reduktion redundanter Einträge.
- ▶ Staging-Phase: Neue Regeln zunächst in Monitoring-Mode (log) beobachten, bevor sie produktiv gehen.
- ▶ Regelmäßige Rezertifizierung: ungenutzte Einträge identifizieren (Hit Count, NetFlow, Firewall-Logs).
- ▶ Automatisierte Tests (Packet-Tracer, Simulationen) nach Änderungen durchführen.
- ▶ Übergang zu Zonen-basierten Policies planen, sobald Stateful Inspection verfügbar ist.

Zone-Based Policy Firewalls

Referenz-Zonenmodell



Grundprinzip der Zonen

- ▶ Interfaces werden genau einer Zone zugeordnet; Verkehr innerhalb derselben Zone bleibt uninspektiert.
- ▶ Zonenpaare (Quelle → Ziel) definieren gültige Verkehrsrichtungen; nicht definierte Paare werden gedroppt.
- ▶ Self-Zone behandelt den Verkehr zur Control Plane (Management, Routing-Protokolle) separat.
- ▶ Default-Aktion ist deny; nur explizit erlaubte Flows werden inspiziert und durchgelassen.

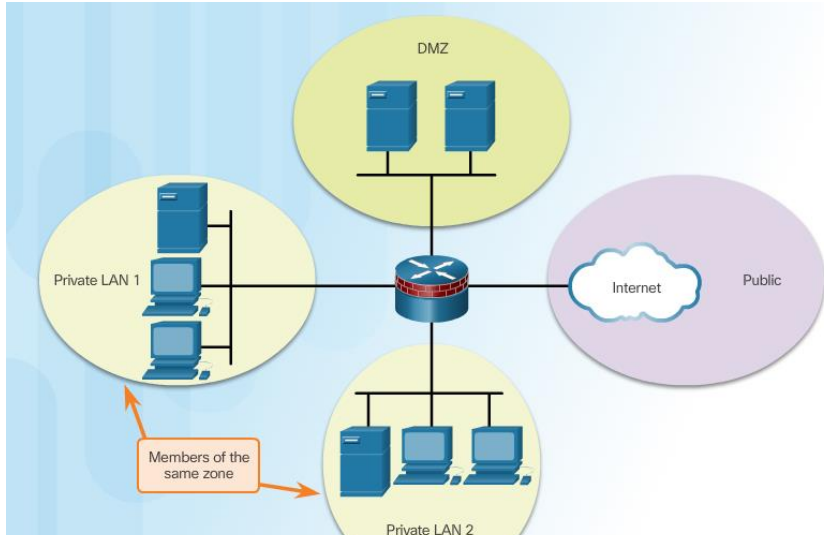
Designmethodik für Zonen

- ▶ Inventarisierung: Welche Sicherheitsdomänen existieren (Benutzer, DMZ, OT, Partner, Cloud)?
- ▶ Datenflussanalyse: Welche Applikationen sprechen zwischen den Zonen? Welche Protokolle/Ports?
- ▶ Risikobewertung: Welche Assets brauchen 'least privilege', welche Zonen erfordern IDS/IPS?
- ▶ Abbildung auf Plattform: Interfaces, Subinterfaces, VLAN-Trunks, virtuelle Systeme.
- ▶ Dokumentation in einer Policy-Matrix (Quelle, Ziel, Service, Begründung, Owner, Expiry).

Policy-Konstruktion

- ▶ **class-map**: gruppiert Protokolle (Layer-4 oder Layer-7) oder Matching-Kriterien (Application IDs).
- ▶ **policy-map**: definiert Aktionen (inspect, pass, drop) und Logging-Level für jede Klasse.
- ▶ Service-Policy wird einem Zone-Paar zugewiesen; Reihenfolge der Klassen bestimmt Priorität.
- ▶ Stateful Inspection trackt erlaubte Sessions und öffnet Rückkanäle; non-TCP-Verkehr nutzt sequenzbasierte Heuristiken.
- ▶ Verwenden von Layer-7-Elementen (z. B. URL-Kategorien) nur dort, wo DPI-Kapazität vorhanden ist.

Zonen-Policy – Visualisierung



Integration mit Routing und NAT

- ▶ Reihenfolge: Routing → NAT → Zone Policy; ACLs im Outside können zusätzlich filtern.
- ▶ Policy muss auf die post-NAT Adressen abgestimmt sein (Identity NAT für interne Zonen erleichtert Betrieb).
- ▶ 'Pass'-Aktion eignet sich für vorvalidierten Verkehr (z. B. nach Upstream-Inspection).
- ▶ Durchsatzmessungen einplanen, sobald Inspektions-Aktionen oder Application Layer Proxies aktiviert werden.

Monitoring und Pflege

- ▶ Kennzahlen: Anzahl aktiver Sessions pro Zone-Paar, Top-Anwendungen, Reject/Drop-Rate.
- ▶ Regelverfall: Automatisierte Reports zu ungenutzten Regeln, Ablaufdaten erzwingen Rezertifizierung.
- ▶ Forensik: Vollständiges Logging für kritische Flows (insbesondere Self-Zone) und SIEM-Integration.
- ▶ Lifecycle: Change-Management, Testumgebungen, 'Policy-as-Code' zur Versionierung.

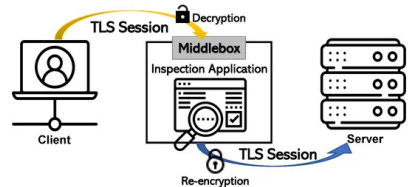
Zonen- und Self-Zone-Besonderheiten

- ▶ Verkehr innerhalb einer Zone wird nicht inspiziert; Inter-Zonenverkehr benötigt immer ein konfiguriertes Zonenpaar.
- ▶ Pro Interface genau eine Zone; Bridging oder Subinterfaces benötigen eindeutige Zuordnung.
- ▶ Self-Zone: Traffic zur Control Plane (SSH, SNMP, Routing) nur mit expliziten Policies zulassen und stark loggen.
- ▶ Reihenfolge auf Edge-Routern: 1) Routing 2) NAT 3) Firewall – wichtig für korrekte Filterung von post-NAT Adressen.

Deep Packet Inspection

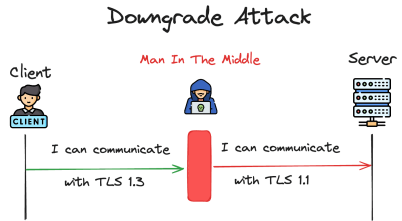
DPI-Analyse-Pipeline

- ▶ Session-Reassembly: Rekonstruktion fragmentierter IP/TCP-Pakete, Stream-Normalisierung.
- ▶ Protokoll-Decoder erkennen Applikationen jenseits von Portnummern (SNI, HTTP, SMB).
- ▶ Aktionen: Block, Reset, Rate-Limit, Benachrichtigung.



TLS-Inspection: Prinzip

- ▶ MITM: Firewall terminiert TLS, erstellt eigenen TLS-Kanal zum Ziel.
- ▶ Client-Trust: Unternehmens-CA verteilen, Ausnahmen definieren (Banking, Healthcare).



TLS-Inspection: Betrieb & Datenschutz

- ▶ Performance: Offload, Ciphers (GCM vs. CBC), PFS beeinflussen Durchsatz und Latenz.
- ▶ Datenschutz/Compliance: Betriebsvereinbarungen, Minimierung, selektive Decryption per Policy.
- ▶ Monitoring: klare Dashboards für Fehlerursachen (Handshake, Zertifikate, Policy-Miss).

NGFW-Services im Kontext

- ▶ **Application Control:** Durchsetzung geschäftlicher Freigaben (z. B. Collaboration vs. Shadow IT).
- ▶ **IDS/IPS:** Signaturen und verhaltensbasierte Erkennung, automatische Quarantäne via dynamische Tags.
- ▶ **Advanced Malware Protection:** File-Carving, Sandbox, Retrospektive Analyse.
- ▶ **Threat Intelligence:** Cloud-Feeds, STIX/TAXII, Anbindung an SOAR-Playbooks.
- ▶ **Automation:** API/REST-Interfaces für Infrastructure-as-Code, Zero-Touch Deployments.

Grenzen und Betriebsmodelle

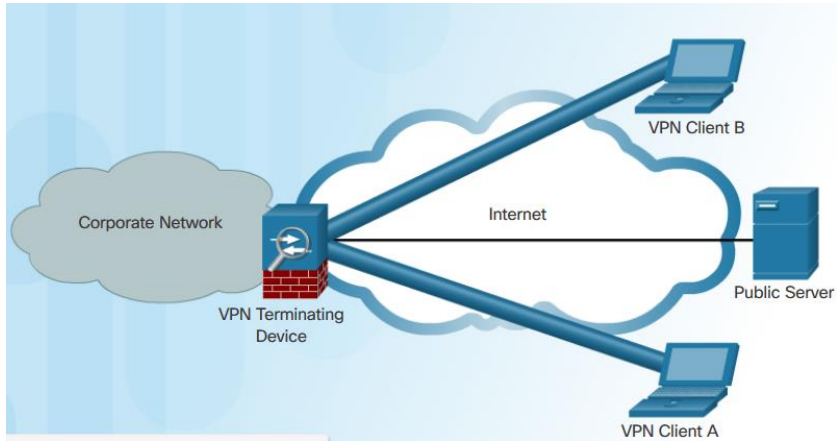
- ▶ Feature-Entscheidungen beeinflussen Lizenzmodell (Subscription-Bundles, Throughput-Tiers).
- ▶ Hybrid-Architekturen: Kombination aus On-Prem NGFW, Cloud Access Security Broker (CASB) und SASE.
- ▶ Fehlalarme und Tuning-Aufwand erfordern dedizierte SOC-Prozesse und regelmäßige Signatur-Updates.
- ▶ Hohe Transparenz verlangt gutes Log-Management: Storage, Retention, Korrelation.

IPsec VPN Foundations

VPN-Szenarien und Topologien

- ▶ Provider-basierte Layer-2/3 VPNs: Carrier stellt Transport, Kundengeräte bleiben simple CE-Router.
- ▶ Site-to-Site VPNs: Statischer Tunnel zwischen Standorten, transparente Kopplung ganzer Netze.
- ▶ Remote Access VPNs: Dynamische Einwahl einzelner Clients mit individueller Authentisierung.
- ▶ Ende-zu-Ende VPNs: Applikationsspezifische Tunnels (z. B. TLS, mTLS) zwischen dedizierten Hosts.
- ▶ Auswahl basiert auf benötigter Kontrolle, Skalierung, Betriebsmodell.

VPN-Topologien – Visualisierung



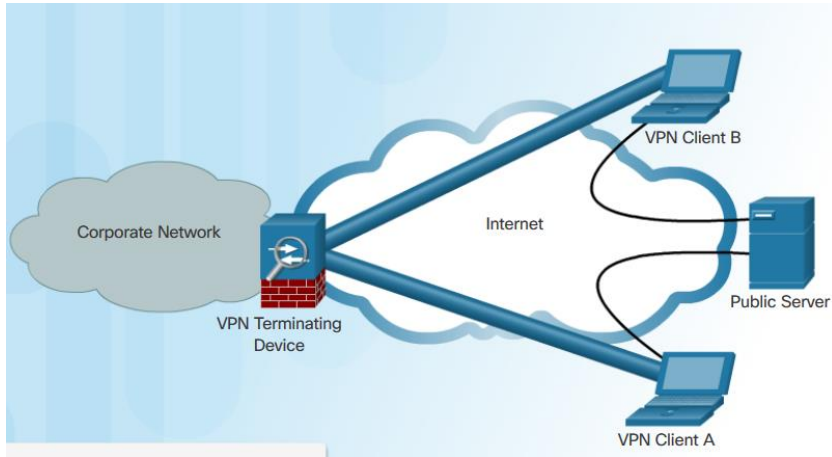
IPsec-Bausteine

- ▶ **IKE/ISAKMP**: Kontrollkanal, verhandelt Krypto-Algorithmen, Schlüssel, Authentisierung.
- ▶ **Security Associations**: Richtungsgebundene Parameter-Sets (SPI, Cipher, Lifetime).
- ▶ **AH vs. ESP**: AH (IP-Protokoll 51) bietet Integrität/Authentizität; ESP (IP-Protokoll 50) bietet zusätzlich Vertraulichkeit sowie Replay-Schutz; jeweils in Transport- oder Tunnel-Mode.
- ▶ **Perfect Forward Secrecy**: Zusätzliche DH-Aushandlung verhindert Schlüsselkompromittierung durch Altmaterial.

AH vs. ESP — Bedeutung und Unterschiede

- ▶ **AH (Authentication Header):** Integrität und Authentizität für IP-Pakete; verschlüsselt **nicht**. Schützt Payload und unveränderliche Teile des IP-Headers.
- ▶ **ESP (Encapsulating Security Payload):** Vertraulichkeit (Verschlüsselung) **und** Integrität/Authentizität, inkl. Replay-Schutz. Auth-only oder Encrypt-only technisch möglich, üblich ist beides.
- ▶ **NAT-Kompatibilität:** AH scheitert meist an NAT (Header ändert sich) → praktisch kaum im Internet. ESP funktioniert mit **NAT-T** (ESP-in-UDP/4500).
- ▶ **Transport vs. Tunnel:**
 - ▶ Transport-Mode: Schutz der L4-Payload (ESP) bzw. Payload+Header-Anteile (AH); Original-IP-Header bleibt erhalten.
 - ▶ Tunnel-Mode: Vollständiges inneres IP-Paket wird geschützt; äußerer IP-Header ist neu.
- ▶ **Praxis:** Moderne Site-to-Site/RA-VPNs nutzen fast ausschließlich ESP (Tunnel-Mode) mit NAT-T und PFS.

IPsec – Betriebsfluss



IKE Phase 1 im Detail

- ▶ IKEv1: Main Mode (6 Nachrichten) vs. Aggressive Mode (3 Nachrichten); Auth über Pre-Shared Keys oder Zertifikate.
- ▶ IKEv2: Vereinheitlichte Nachrichtenstruktur, schnellere Rekeying-Prozesse, MOBIKE-Unterstützung für Road Warrior.
- ▶ Wichtige Parameter: Verschlüsselung (AES-GCM vs. AES-CBC), Hash (SHA-2), DH-Gruppe, Lifetime.
- ▶ Ergebnis: IKE SA, die für Phase-2-Aushandlungen und Rekeying genutzt wird.

Phase 2 und Traffic Selector

- ▶ Quick Mode (IKEv1) bzw. CHILD_SA (IKEv2) definiert ESP-Parameter, Perfect Forward Secrecy optional.
- ▶ Traffic Selector beschreibt 'interesting traffic' (Subnetze, Ports, Protokolle), Policy-based vs. Route-based Tunnel.
- ▶ SPI-Zuordnung erfolgt pro Richtung; Replayschutz basiert auf Sequenznummern und Sliding Window.
- ▶ Rekeying vor Ablauf der Lifetime verhindert Session-Drops; konsistente Timings auf beiden Seiten notwendig.

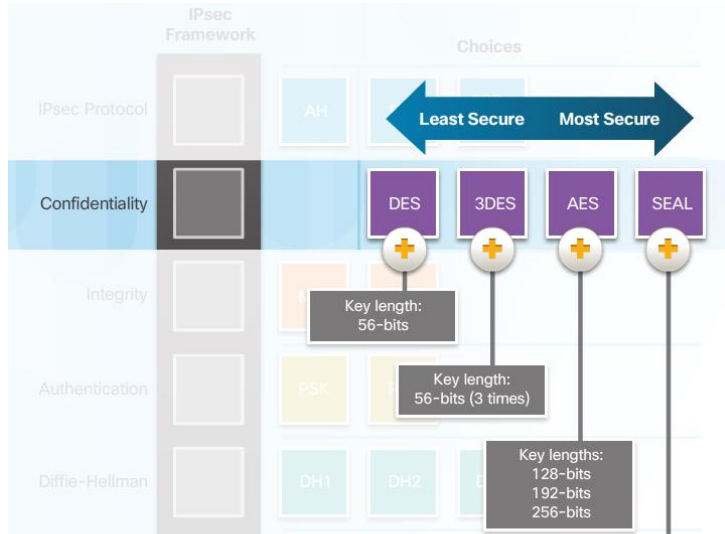
IPsec Design-Aspekte

- ▶ Crypto Map (policy-basiert, am physischen Interface angewendet) vs. Virtual Tunnel Interface (route-basiert).
 - ▶ Crypto Map: **kein** echtes Tunnel-Interface — **interessanter Verkehr** wird per ACL ausgewählt und auf dem Ausgangs-Interface verschlüsselt.
 - ▶ Virtual Tunnel Interface (VTI): **echtes** (virtuelles) L3-Interface mit eigener IP/MTU; Weiterleitung über die Routing-Tabelle (statisch/dynamisch), geeignet für Multicast/DRP.
- ▶ NAT-Traversal (UDP/4500) und Identity-Handling (IKE-IDs, FQDN vs. IP) sauber abstimmen.
- ▶ MTU/MSS: Fragmentierung vermeiden (PMTU-Discovery, MSS-Clamping) und Edge-Konfiguration prüfen.

IPsec Betrieb & Failover

- ▶ Überwachung: SLA/Track-Objekte, Dead Peer Detection, Rekeying-Zeitpunkte.
- ▶ Redundanz: HSRP/VRRP, Active/Standby Peers, SD-WAN-Pfadselektion.
- ▶ Dokumentation: Schlüssel-/Zertifikatslaufzeiten, Change-Historie, Notfallprozeduren.

IKE/IPsec Visuals



Troubleshooting und Telemetrie

- ▶ Prüfen von IKE- und IPsec-SAs (Status, Lifetimes, Bytes, Fehlerzähler).
- ▶ Analyse von Aushandlungs-Logs (IKE Debugs) zur Identifikation von Policy-Mismatch (Proposal, Pre-Shared Key, Identity-ID).
- ▶ Erweitertes Ping/Traceroute mit Quell-IP prüft Tunnel-Endpunkte und Routing.
- ▶ Korrelation mit Firewall-Logs (Zone-Paare, ACLs) stellt sicher, dass interessanter Verkehr nicht vor Erreichen des Tunnels blockiert wird.

Important Commands

ACL und Baseline-Firewall

- ▶ `ip access-list extended ACL_USERS permit tcp 10.10.10.0 0.0.0.255 host 203.0.113.10 eq 443`
- ▶ `ip access-list extended ACL_USERS deny ip any any log`
- ▶ `show access-lists ACL_USERS`: Trefferzähler und Reihenfolge prüfen.
- ▶ `ip access-list resequence ACL_USERS 10 10`: Platz für neue Regeln schaffen.
- ▶ `show platform hardware acl statistics`: Ressourcenauslastung bewerten.

Zone-Based Firewall

- ▶ `zone security INSIDE zone security OUTSIDE zone security DMZ`: Zonen definieren.
- ▶ `class-map type inspect match-any CM_WEB match protocol http match protocol https`
- ▶ `policy-map type inspect PM_INSIDE class type inspect CM_WEB inspect`
- ▶ `zone-pair security ZP_IN_OUT source INSIDE destination OUTSIDE`
- ▶ `service-policy type inspect PM_INSIDE`: Policy zuweisen.
- ▶ `show policy-map type inspect zone-pair sessions`: Aktive Sessions kontrollieren.

IPsec Site-to-Site

- ▶ `crypto isakmp policy 10 encryption aes 256 hash sha256 group 24 lifetime 3600`
- ▶ `crypto isakmp key <secret> address <peer>`: Authentisierung.
- ▶ `crypto ipsec transform-set TS_1 esp-aes 256 esp-sha-hmac`
- ▶ `crypto map CMAP 10 ipsec-isakmp match address VPN_ACL set peer <peer-ip> set pfs group24`
- ▶ `interface GigabitEthernet0/0 crypto map CMAP`: Anwendung auf Ausgangsinterface.
- ▶ `show crypto isakmp sa / show crypto ipsec sa`: Tunnelstatus und Counters.